WG 5 Introduction to ANCR 27560 Exchange Profile Model v1

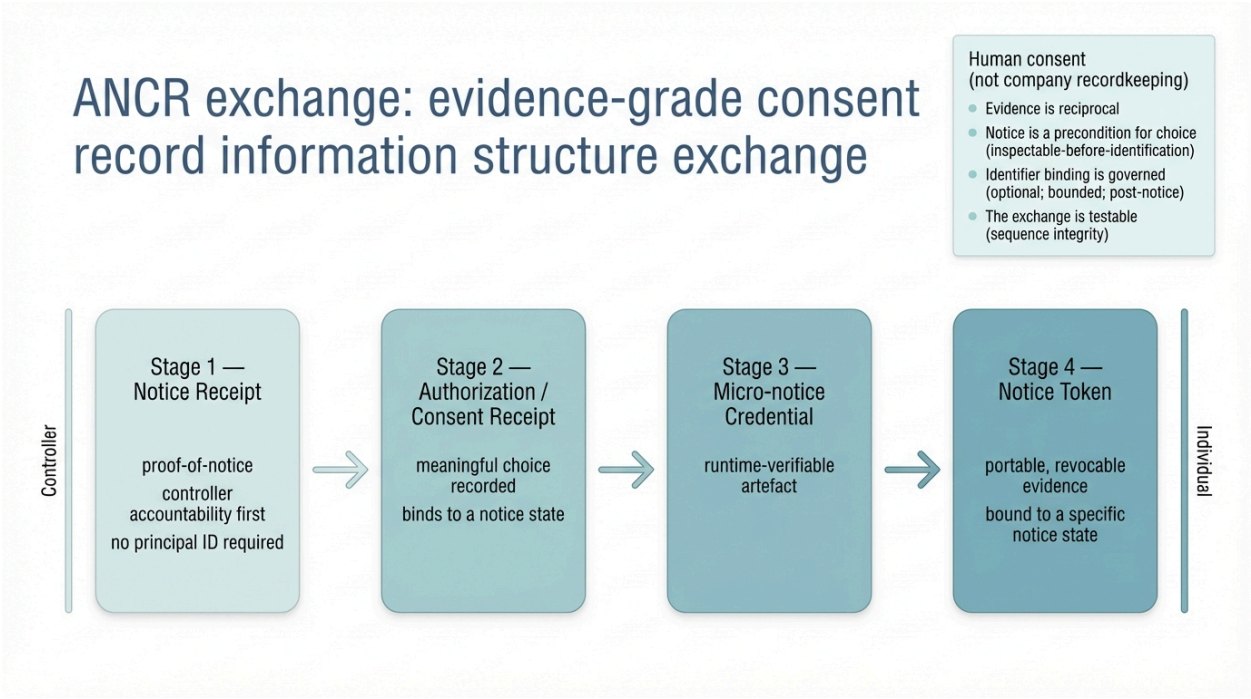
A Glass-boxed Digital ID & AI Governance Exchange Model for Digital Wallet and AI Governance Interoperability

How to read (fast): this appendix is a **computable minimum-evidence rule**. It connects (1) ANCR stages, (2) assurance levels, and (3) scope of disclosure so implementers and auditors can determine **what must be provable** at each risk scope.
Context: The ANCR 4 stage notice receipt exchange imitates phyiscal consent pattern, to produce digital-id and ai consent based flows for any legitimate legal context, dynamically. PII Principles choose to be digitally identified, to generate consent receipt.
WG5 ANCR Digital Consent Presentation Deck

- 27560 Anchored Notice and Consent Receipt Profile
    - See V1.02 on Github for full profile

Quick navigation:

- Core model (Stages × Levels × Scope)
- Scope of disclosure categories
- Trusted Transparency Assurance levels
- 4 stages (artefact chain)
- Compute the required minimum
- Why this closes the 27560 failure mode



At-a-glance summary (Stages × Levels × Scope):

Dimension	What it controls	Output (what must exist)
Stages (1–4)	Which evidence artefacts exist	Notice Receipt → Authorization/Consent Receipt → Micro-notice Credential → Notice Token
Levels (1–4)	How strongly claims must be independently testable	Disclosure exists → Structured evidence → Verifiable governance → Assured interoperability
Scope of disclosure (4 categories)	Why assurance must increase (risk driver)	Private/Interior → Intimate/Relational → Physical Public/Proximity-Bounded → Digital/Networked

▼ Core model (Stages × Levels × Scope)

This is the integration mechanism (glass-boxed governance) that connects:

- the **4-stage ANCR exchange** (what artefacts exist)
- the **4 assurance levels** (what must be true / testable at a given risk level)
- the **scope of disclosure** (why the assurance requirement increases)

The term “glass box” is intentional: it means the governance claims are **inspectable by external parties** (individuals, auditors, regulators) rather than asserted as internal compliance.

1) Core Glass-boxed Concept

As scope of disclosure expands (local → international), the risks of linkability, invisible recipients, and non-repudiable identifier binding rise. The framework therefore raises the minimum evidence requirements.

- **Stages** define the artefact chain: Notice Receipt → Consent Receipt → Micro-notice Credential → Notice Token
- **Levels** define what must be independently testable at that scope (from “basic disclosure exists” to “portable, revocable evidence interoperates across jurisdictions”)
- **Scope of disclosure** is the driver: wider disclosure requires stronger portability, revocation propagation, and governance verification.

2) Scope of disclosure (risk driver)

This profile uses four required scope-of-disclosure categories (D&O classifier). These categories are the bridge between human expectations and machine-checkable governance.

1. **Private / Interior (no disclosure)**
    - No disclosure beyond the individual’s private/interior context.
    - Default: no network disclosure.
2. **Intimate / Relational (family, friends, close community)**
    - Disclosure within a bounded trust relationship.
    - Escalation rule: durable recording, onward sharing, or automation escalates toward Digital scope.
3. **Physical Public / Proximity-Bounded**
    - Disclosure constrained by proximity, line-of-sight, and time.

- Escalation rule: recording, indexing, biometric identification, or automated correlation breaks proximity and escalates toward Digital scope.

4. **Digital / Networked (beyond 1–3; scalable disclosure)**
    - Disclosure is routable, recordable, copyable, searchable, and transferable across systems/parties/time.
    - Required: notice, permission when consent is the legal basis, and legitimate purpose + proof of authority, with externally inspectable evidence (glass box governance).

Mapping note (implementation): when existing fields require `scope_of_disclosure` values, map as:

- Private/Interior → `individual_only`
- Intimate/Relational → `community`
- Physical Public/Proximity-Bounded → `local`
- Digital/Networked → `regional` / `national` / `international` (depending on propagation)

3) Assurance levels (what is required to claim conformance at each risk level)

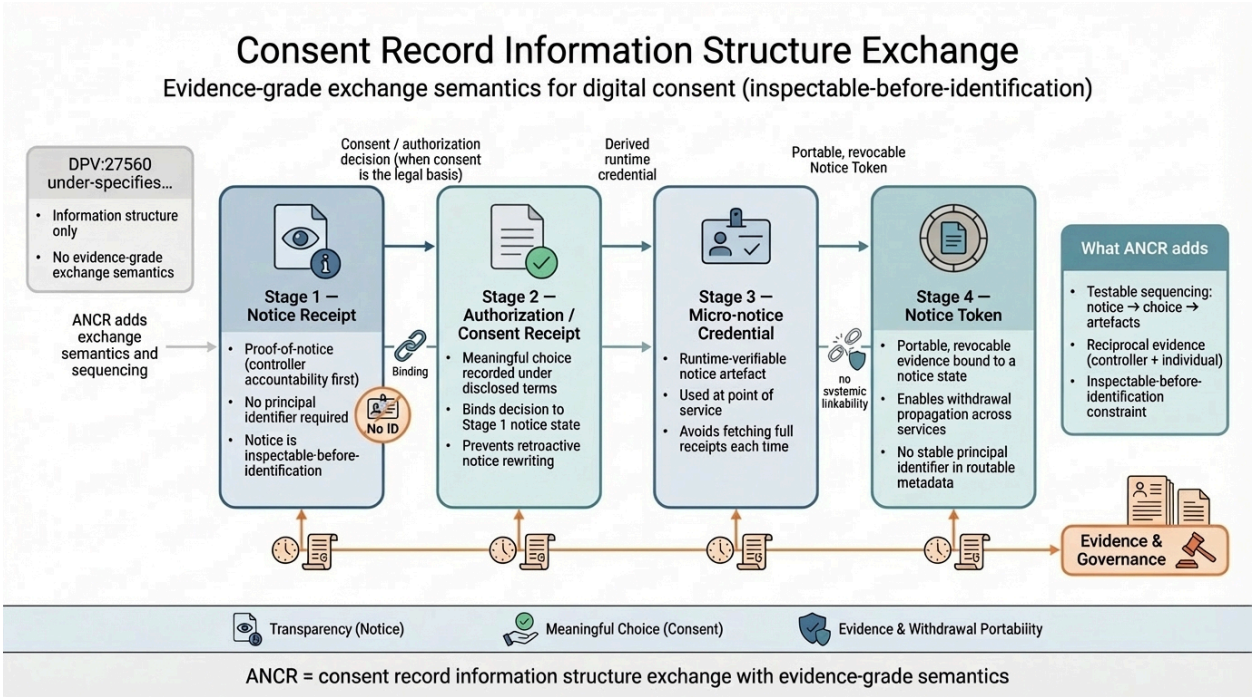
These levels are cumulative: Level N includes Level 1..N requirements.

1. **Level 1 — Basic Disclosure**
    - Self-Asserted Minimum controller-id record presented
    - Artefacts may be produced but are not independently verified
    - Primary objective: stop “no notice at all” implementations
2. **Level 2 — Structured Evidence**
    - Consistent schema used across deployments
    - Notice-first sequencing is demonstrable (timestamps/events)
    - Artefacts are exchangeable and comparable across implementations
3. **Level 3 — Verifiable Governance**

- **Code of Conduct commitments** expressed and verifiable
- **TPI signals** available for regulatory review (glass-boxed governance)
- Suitable for regulated digital identification deployments where assurance must be inspectable

4. **Level 4 — Assured Interoperability**
   - Full ANCR exchange implemented (Stages 1–4)
   - Cross-jurisdiction portability works in practice
   - Withdrawal/notice-state changes propagate via portable evidence (tokens) across services
   - Applies to AI-enabled orchestration and high-risk digital identification contexts

4) The 4 stages (artefact chain) and what each stage contributes



1. **Stage 1: Notice Receipt**
   - Proof-of-notice issued to the individual
   - Controller accountability established before identification

- Enables the “inspectable-before-identification” safety gate

2. **Stage 2: Consent / Authorization Receipt**
   - Records meaningful choice under disclosed terms (when consent is the legal basis)
   - Binds the decision to a notice state (prevents retroactive notice rewriting)
3. **Stage 3: Micro-notice Credential**
   - Runtime-verifiable artefact (checkable at point of service)
   - Reduces need to fetch full receipts while preserving evidence semantics
4. **Stage 4: Notice Token**
   - Portable, revocable evidence token bound to a specific notice state
   - Enables withdrawal propagation and cross-service enforcement without identifier-first gates

What makes it “human consent” (not company record-keeping)

- Evidence is reciprocal (held by both controller and individual)
- Notice is a precondition for choice (inspectable-before-identification)
- Identifier binding is governed (optional; bounded; post-notice)
- The exchange is testable (sequence integrity can be validated)

5) How to “compute” a required minimum (practical rule)

1. Classify the **scope of disclosure** (local/community/regional/international).
2. Set the **minimum assurance level** for that scope.
3. Require the **stage set** needed to satisfy that level.

Recommended baseline mapping (draft):

- **Local** → Level 1–2 (Stages 1–2)
- **Community / organisational** → Level 2–3 (Stages 1–3)
- **Regional / national** → Level 3 (Stages 1–3, plus governance + TPI)

- **International / cross-border / AI-orchestrated** → Level 4 (Stages 1–4)

6) Why this closes the ISO/IEC CD 27560: PII Processing first failure mode

The ISO/IEC CD 27560:2026 failure mode is "identifier-first controller record-keeping labelled as consent evidence."

This framework prevents that by making three claims testable:

- **Sequencing**: notice before identification and before collection/use/transfer
- **Governance**: Code of Conduct + measurable TPI signals at higher scopes
- **Withdrawal portability**: revocation/notice-state changes propagate without requiring a stable `pii_principal_id` as a public rights access key

See DIACC: Report on Adequacy of Identity Governance Transparency: Featuring International/Digital-ID Notice Requirements for digital-Id Wallet Governance Interoperability https://diacc.ca/2022/03/31/adequacy-of-identity-governance-transparency/

Why ANCR matters for digital wallets (unlinkability is a design constraint)

Digital wallet consent cannot be built on identifier-first record structures without creating systemic linkability risk. Unlinkability is a key provision in eIDAS-aligned wallet thinking and in modern wallet assurance debates.

ANCR supports wallet consent because it:

- allows a Stage 1 interaction without principal identification
- treats any identifier binding as a governed disclosure event
- supports portable evidence (Notice Tokens) without forcing a stable principal identifier into routable metadata